

High:

H1: Arbitrary File Upload

Matrix Calculation		CVSS Score	Risk
Impact	High	8.7	High
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N</u>	
MITRE ATT&CK	Techniques	<u>T1505.003: Server Software Component - Web Shell</u> <u>T1204.002: User Execution - Malicious File</u>	
	Mitigations	<u>M1048: Application Isolation and Sandboxing</u> <u>M1050: Exploit Protection</u>	
Affected Scope			

Description

The **Avatar Image Upload** allows user to upload any arbitrary file type. This allows user to upload malicious code as their avatar picture that will execute on the backend server when uploaded and rendered.

Business Impact

This vulnerability gives attackers remote code execution on the backend server by uploading malicious scripts as an avatar picture. This can lead to system compromise if attackers execute a reverse shell script.

Steps to Reproduce

- Step 1: Navigate to the **Edit Profile** page and select **avatar image**
- Step 2: Upload a PHP reverse shell as the **avatar image**:
- Step 3: Start a netcat listener
- Step 4: Click save to upload the reverse shell
- Step 5: Observe call back on netcat listener

Remediations

Team-XX recommends the following:

1. Enforce file type restrictions through a whitelist, such that only common image types should be allowed, such as .img, .jpg, .png. Disallow all other file types.
2. Set the permission of user uploaded files to be non-executable.
3. Containerize the application to minimize impact in case of abuse.
4. Utilize a web application firewall to filter malicious uploads.
5. Sandbox the application and restrict its permissions to avoid remote command execution on the server.

References

[Pentestmonkey: PHP Reverse Shell](#)

[OWASP - Unrestricted File Upload](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

H1: XML External Entity (XXE)

Matrix Calculation	CVSS Score	Risk
--------------------	------------	------

Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application T1005: Data from Local System	
	Mitigations	M1050: Exploit Protection M1038: Execution Prevention M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

The **application** allows attackers to interfere with the processing of XML data. The attacker can then inject malicious XML containing external entities that can be used to access local files, perform denial-of-service attacks, and execute SSRF attacks.

Business Impact

An attacker can leverage this vulnerability to exfiltrate confidential data stored in files from the machine, as well as take down services for long periods of time through XML bomb denial-of-service attacks

Steps to Reproduce

Step 1: Find an editable XML request being sent to the sever

```
<?xml version="1.0" encoding="UTF-8"?>
```

```
<stockCheck><productId>381</productId></stockCheck>
```

Step 2: Inject an XML external entity that can be used to read any file on the system

```
<?xml version="1.0" encoding="UTF-8"?>
```

```
<!DOCTYPE foo [ <!ENTITY xxe SYSTEM "file:///etc/passwd" ]>
```

```
<stockCheck><productId>&xxe;</productId></stockCheck>
```

Remediations

Team-XX recommends the following:

1. Disable external entities in XML parsers, preventing the attack from ever being possible.
2. Perform input validation, specifically disallowing !DOCTYPE declarations.
3. Use safe parsing libraries.
4. Install a web application firewall to block dangerous XML requests
5. Sandbox the application and restrict its permissions to avoid remote command execution on the server.

Resources

[OWASP - XXE Explained](#)

[OWASP - XXE Prevention Cheatsheet](#)

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

H1: File Permission Enabled on MySQL Server

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application T1005: Data from Local System	
	Mitigations	M1050: Exploit Protection M1038: Execution Prevention M1048: Application Isolation and Sandboxing	
Affected Scope			

Description

The SQL user has the FILE permission enabled. This allows an attacker to read and write files to the computer, potentially achieving Remote Code Execution by writing a web shell or writing to a file that gets executed.

Business Impact

An attacker can leverage this vulnerability to exfiltrate confidential data stored in files from the machine, overwrite important files, as well as potentially achieve remote code execution on the server.

Steps to Reproduce

Step 1: Login to the SQL server

Code block: `mysql -u root -p`

Step 2: `SELECT grantee, privilege_type FROM information_schema.user_privileges WHERE grantee = "currentuser"`

Remediations

Team-XX recommends the following:

1. Audit user permissions and disable unnecessary ones
2. If FILE permission is required, make sure `secure_file_priv` is set to restrict what files to SQL user can read and write to

Resources

[MySQL privileges documentation](#)

H1: Unnecessary Administrator Privileges for All Users

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1078: Valid Accounts T1098: Account Manipulation	
	Mitigations	M1026: Privileged Account Management M1018: User Account Management	
Affected Scope			

Description

All users on the system currently possess administrative privileges. This allows any user on the system to be able to modify key parts of the system, as well as view all sensitive information present on the system.

Business Impact

The system directly violates the Principle of Least Privilege by allowing non-administrator users to have administrative access to the system. This compromises confidentiality and integrity, as any user can view and manipulate sensitive data on the system. This also enables an attacker to immediately have administrator access if gaining unauthorized access to any user on the system.

Steps to Reproduce

Step 1: List all users

Step 2: See they all have administrative access

Remediations

Team-XX recommends the following:

1. Audit user permissions such that any non-administrator user does not have administrative access on the system
2. Implement administrative access policies so that there is a clear procedure to ensure only required users have admin privileges on the system.

Resources

CrowdStrike - Principle of Least Privilege

CISA - Weak User Management and Security Controls

H1: Unpatched Kernel Vulnerability - OverlayFS

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1608: Exploitation for Privilege Escalation	
	Mitigations	M1051: Update Software	
Affected Scope			

Description

The following machine contains a kernel vulnerability – CVE-2021-3493, OverlayFS, which allows a user to escalate privileges from an unprivileged user to root, by smuggling an SUID binary from a lower directory to an upper directory, with the use of OverlayFS as an intermediary.

Business Impact

Given an attacker has unprivileged access to the system, they can take over the root user, giving them complete control over the system. With this, they can enumerate for more sensitive information or modify or turn off services running on the machine.

Steps to Reproduce

Step 1: Downloaded the exploit from: <https://github.com/briskets/CVE-2021-3493>

Step 2: Upload the exploit C code to the machine via SCP using the **USER** user

Step 3: Once on the machine, compile the exploit code using gcc:

Step 4: Run the executable file to obtain root access

Remediations

Team-XX recommends the following:

1. All machines are updated to the latest version available, as exploits such as these are fixed rapidly within days of discovery.

2. An auto-patching solution can automate the patching process, ensuring all systems are up to date without manual intervention.
3. Note that an Ubuntu or Debian based system is likely to be vulnerable if it has a kernel version below 6.2, which can be verified with the command:
uname -r.

References

[NIST - CVE-2023-0386](#)

[WIZ - Ubuntu Overlay Vulnerability Explanation](#)

H1: Editable Scheduled Task Running as Administrator

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1053.005: Scheduled Task/Job - Scheduled Task	
	Mitigations	M1022: Restrict File and Directory Permissions M1026: Privileged Account Management	
Affected Scope			

Description

The machine contains a scheduled task that runs a script controlled by **USER**. This scheduled task runs as Administrator, which can then be modified by a low privileged user to escalate to the Administrator account.

Business Impact

An attacker can change the intended purpose of the scheduled task which will impact business operations. The attacker can also use the scheduled task to gain Administrator access, gaining Administrator access to the system.

Steps to Reproduce

- Step 1: Locate the file in the files of the **USER** user
- Step 2: View permissions of the file to see that it is run as Administrator
- Step 3: Modify the batch file to run a reverse shell when executed
- Step 4: Create a listener and wait for a connection when the scheduled task runs.

Remediations

Team-XX recommends the following:

1. All scheduled tasks that must be run as Administrator should only be editable by the Administrator account.
2. If a scheduled task does not need administrative privileges to run, it should not have admin privileges to follow the Principle of Least Privilege and prevent privilege escalation attempts.
3. Centralize scheduled task management via Group Policy to allow for deployment and tracking of scheduled tasks centrally.

References

H1: PrintNightmare

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	

MITRE ATT&CK	Techniques	T1608: Exploitation for Privilege Escalation
	Mitigations	M1051: Update Software
Affected Scope		

Description

The PrintNightmare exploit, CVE-2021-1675, abuses a set of vulnerabilities in Windows Print Spooler that allows an attacker to escalate their privileges from a low-level user to Administrator. An attacker with a low-privileged local account can install a malicious print driver to escalate privileges to Administrator.

Business Impact

If an attacker gains complete control of the machine, allowing them to shut down critical services running on the machine, see sensitive documents stored on it, and also use the machine to pivot and attack other machines.

Steps to Reproduce

Step 1: Log into the machine as **USER** user.

Step 2: Download the powershell POC implementation from <https://github.com/calebstewart/CVE-2021-1675>

Step 3: Import the module

Step 4: Run Invoke-Nightmare

Step 5: Log in as the new user

Remediations

Team-XX recommends the following:

1. Apply at least Microsoft patch KB5004945 mitigating the PrintNightmare vulnerability.
2. An auto-patching solution can automate the patching process, ensuring all systems are up to date without manual intervention.
3. Printspooler be disabled on machines that do not need printing access for attack surface reduction.
4. Implement Windows Defender or another Antivirus solution to detect and prevent common AD attacks.

References

[Microsoft - PrintNightmare Security Guidance](#)

[Microsoft - PrintNightmare Security Patch](#)

[CISA - PrintNightmare Security Advisory](#)

H1: Exposed SSH Keys

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1552.004: Unsecured Credentials - Private Keys	
	Mitigations	M1022: Restrict File and Directory Permissions M1026: Privileged Account Management M1047: Audit M1027: Password Policies	
Affected Scope			

Description

The machine contains the private ssh key for root login to the following machines.

Business Impact

If an attacker gains unauthorized access to this machine, they can pivot to further machines as root.

Steps to Reproduce

Step 1: Log into the machine as **USER** user.

Step 2: Enumerate the file system and discover the private ssh key in **the following directory**.

Step 3: Use the found private key to log into **further machines** as root.

Remediations

Team-XX recommends the following:

1. All SSH keys for Administrator or Root access should be password protected. This ensures low-privilege accounts cannot utilize these keys to gain full-system access and pivot to more of the network.
2. The leaked private keys should be disabled and removed from all APT systems.
3. Future SSH keys should be stored in a more secure manner such as inside internal private servers that are not accessible by low-privileged user accounts.

References

[NIST - Recommendation for Key Management](#)

[NIST 800-53 Controls for SSH Key Access and Storage](#)

H1: Stored Cross Site Scripting

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1189: Drive-by Compromise T1059: Command and Scripting Interpreter - JavaScript	

		T1539: Steal Web Session Cookies T1190: Exploit Public Facing Application
	Mitigations	M1021: Restrict Web Based Content M1054: Software Configuration M0818: Validate Program Inputs
Affected Scope		

Description

User input is stored on the website and then executed as JavaScript when viewed. This allows an attacker to upload a malicious script as user input, which rendered by another user or APT Admin, will send the cookie to the attacker, leading to session hijacking.

Business Impact

This could allow a malicious actor to steal cookies of other users, impersonating others including higher-level users with permissions. It can also impact the availability of the site, making web pages appear blank when visited.

Steps to Reproduce

Step 1: Create a post with the following payload `<script>alert(1)</script>`

Step 2: View the post

Remediations

Team-XX recommends the following:

1. Validate and normalize all user input on the server with a whitelist where possible. Always encode output and never store raw HTML or JavaScript from untrusted user input without sanitization.
2. Implement a Web Application Firewall to block malicious JavaScript payloads.
3. Utilize a strict Content Security Policy to restrict JavaScript sources.
4. Mark session cookie configurations as *HttpOnly*, *Secure*, and *SameSite=Strict* to protect cookies from exfiltration.

References

[Mozilla - Secure Cookie Configurations](#)

[Portswigger - Cross Site Scripting Prevention](#)

[OWASP - XSS Attacks](#)

H1: SQL Injection

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application T1005: Data from Local System T1213: Data from Information Repositories	
	Mitigations	M1048: Application Isolation and Sandboxing M0818: Validate Program Inputs M1050: Exploit Protection	
Affected Scope			

Description

The **X** parameter on the **/[page]** is vulnerable to **X** and **X** based SQL injection. This can be used to access the **X** database stored on **X** machine.

Business Impact

This allows an adversary to have the ability to modify the SQL statement to view the contents of any entry across the entire database, including in other tables. This could potentially allow access to confidential user data such as password hashes, personal information, and confidential business information.

Steps to Reproduce

Step 1: Using a tool such as Burp Suite, capture a request of X (Website, Login Request, Search Request, etc.)

[Picture of Burp Suite Capture]

Step 2: Using a tool like SQLMap, attach the request and get the database name or other database and table information.

Command: [SQLMap Command]

[Picture of SQLMap Command Completed]

Remediations

Team-XX recommends the following:

1. Patch the source code to include proper input sanitization when handling the X parameter to prevent user input from overwriting the intended SQL statement.

References

[OWASP - SQL Injection](#)

[OWASP - SQL Injection Prevention Cheat Sheet](#)

H1: MSSQL PowerShell Command Execution

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:A/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1059: Command and Scripting Interpreter	
	Mitigations	M1038: Execution Prevention, Mitigation	

Affected Scope	
----------------	--

Description

The MSSQL Server has xp_cmdshell has been enabled, though typically disabled by default. This allows for an attacker to run PowerShell commands from the SQL Server environment, giving an attacker arbitrary code access as NT Authority\SYSTEM.

Business Impact

An attacker that has gained unauthorized access to the MSSQL Server can run arbitrary code execution, as a highly privileged user on the backend windows system. This allows an attacker to run a reverse shell script that gives them access to the Windows server, gaining complete control and access to sensitive data and internal systems.

Steps to Reproduce

Step 1: Log into the MSSQL Server with previous found credentials.

Step 2. Run xp_cmdshell whoami to verify privilege level and that xp_cmdshell is enabled

Step 3. Use xp_cmdshell to run a PowerShell reverse shell to gain access to the Windows server.

Remediations

Team-XX recommends the following:

1. If xp_cmdshell is not required for normal business operations, use sp_configure or Policy Based Management to disable the feature.
2. If this feature is required, use the sp_xp_cmdshell_proxy_account system to configure xp_cmdshell to use a least-privileged account that has minimal risk of abuse.

3. Ensure strong credentials are in place to access the MSSQL Server, to ensure only authorized users can access the server.

References

[Microsoft - XP CMDSHELL](#)

H1: FTP Credential Leak

Matrix Calculation		CVSS Score	Risk
Impact	High	8.8	High
Likelihood	High		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:L/VA:L/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1552.001 - Unsecured Credentials: Credentials in files	
	Mitigations	M1047: Audit M1027: Password Policies M1050: Exploit Protection	
Affected Scope			

Description

The machine hosts an FTP server that permits anonymous logon and sensitive information, including plaintext credentials for system users was discovered within the files stored on the server.

Business Impact

An attacker can use the exposed credentials to gain unauthorized access to other systems and application within the network, potentially leading to a full system compromise. This can result in sensitive data being stolen, financial loss, and reputational damage.

Steps to Reproduce

Step 1: Log into the FTP server with anonymous access

Step 2: Recursively list the files on the server to identify sensitive files with 'ls -R'.

Step 3: Download any suspicious files using the get command.

Step 4: Examine the contents of the downloaded file **X** and confirm the presence of plaintext credentials.

Remediations

Team-XX recommends the following:

1. Disable anonymous access by modifying the FTP server's configuration file to completely disallow anonymous logins if sensitive/confidential information is stored on the server.
2. Audit and remove any sensitive files from the FTP Server directories. Implement a strong policy against storing such information on network shares.
3. Implement firewall policies to block the FTP server from being accessible from the outside internet and only from trusted internal network segments.

References

[Cerberus - How to Secure an FTP Server](#)

[Phoenixnap - Configuring Firewall with UFW on Ubuntu](#)

[CISA - Securing Network Infrastructure Devices](#)

H1: UAC Disabled

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1548.002: Abuse Elevation Control Mechanism - Bypass User Account Control	
	Mitigations	M1052: User Account Control	
Affected Scope			

Description

The machine has User Account Control (UAC) disabled or configured to the lowest setting, "Never Notify". UAC is a Windows security component that prevents unauthorized changes by requiring administrative verification for actions affecting the operating system. With UAC disabled, any user can execute code

with administrative privileges without verification, which is a significant security vulnerability.

Business Impact

An attacker who gains low-privilege access can escalate their privileges to a full administrator. This leads to a full system compromise, allowing attackers to steal sensitive data and move laterally to compromise other systems on the network.

Steps to Reproduce

Step 1: Log into the affected Windows machine with a user.

Step 2: Attempt to open PowerShell as administrator and observe that it opens immediately without a UAC prompt.

Remediations

Team-XX recommends the following:

1. Enable UAC and set it to the default “Notify me only when apps try to make changes to my computer” or higher.
2. Set the correct UAC settings via Group Policy Objects (GPO) to enforce it across a domain environment, preventing users from disabling it and ensuring a consistent security posture.

References

[Microsoft - User Account Control Overview](#)

H1: Excessive Sudo Permissions

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	

MITRE ATT&CK	Techniques	T1548.003 - Abuse Elevation Control Mechanism: Sudo and Sudo Caching
	Mitigations	M1028: Operating System Configuration M1026: Privileged Account Management M1022: Restrict File and Directory Permissions
Affected Scope		

Description

The **USER** user is able to use **BINARY** with Sudo permissions. This can be abused to elevate privilege from a non-privileged user to root.

Business Impact

This allows an adversary with access to the system who gained unauthorized access to the **USER** user to obtain root permissions on the system. This allows the attacker to take down or modify the systems hosted on the machine, and access any sensitive information stored on it.

Steps to Reproduce

Step 1: Log into the FTP server with anonymous access

Step 2: Enumerate the FTP server to find the sensitive information

Remediations

Team-XX recommends the following:

1. **BINARY** permissions be removed from the user if the Sudo permission is unnecessary.
2. Never grant broad *ALL* or wildcard command permissions, constrain allowed commands to a single absolute path and to only exact subcommands required.
3. Require authentication and remove *NOPASSWD* so actions are accountable and require user credentials.
4. ATP should implement the Principle of Least Privilege to ensure that each user does not have more permissions than absolutely necessary for business operations.

References

[Red Hat - Managing Sudo Access](#)

[CrowdStrike - Principle of Least Privilege](#)

H1: SMB Signing Disabled

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:A/AC:L/AT:N/PR:N/UI:P/VC:H/VI:H/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1021.002: Remote Services - SMB/Windows shares T1557.001: Adversary in the Middle - LLMNR/NBT-NS Poisoning and SMB Relay	
	Mitigations	M1037: Filter Network Traffic M1042: Disable or Remove Feature or Program	
Affected Scope			

Description

Team-XX discovered the listed hosts as having SMB signing disabled. This leaves the machines vulnerable to an NTLM relay attack, potentially allowing attackers to steal credentials or fake authentication to certain windows services.

Business Impact

This allows an adversary to compromise a service account, which can lead to a data breach, lateral movement across the network, and potential domain compromise if the account has high privileges. They can also cause severe operational disruption by modifying the service that the service account controls.

Steps to Reproduce

Step 1: Use responder to create an NTLM server that can intercept authentication requests.

Remediations

Team-XX recommends the following:

1. Enable SMB Signing across all machines on APT's network through the Computer Group Policy.
2. If an application requires SMB signing to be disabled, disable NTLM authentication.

References

[Microsoft - Configure SMB Signing](#)

H1: Unencrypted HTTP Traffic

Matrix Calculation		CVSS Score	Risk
Impact	High	7.1	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:N/AC:L/AT:N/PR:N/UI:P/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T0842 - Network Sniffing	
	Mitigations	M0808 - Encrypt Network Traffic	
Affected Scope			

Description

The application was found to be transmitting sensitive data over unencrypted HTTP traffic, which allows an attacker on the same network to intercept, read, and modify the traffic in transit. If a user enters any login credentials, session tokens, or personal data, it is sent in cleartext and is exposed to potential eavesdropping.

Business Impact

An attacker can exploit this vulnerability by conducting a man-in-the-middle (MITM) attack, leading to the compromise of user accounts and theft of sensitive information. This can result in unauthorized access to systems, data breaches, financial loss, and damage to APT's reputation.

Steps to Reproduce

Step 1: Use a network sniffing tools like Wireshark to capture network traffic.

Step 2: Filter the captured traffic for HTTP protocol.

Step 3: Interact with the web application and observe the captured packets to view the sensitive data being transmitted in cleartext.

Remediations

Team-XX recommends the following:

1. Enforce HTTPS by implementing TLS (Transport Layer Security) across the entire website to encrypt all data transmitted between client and server.
2. Also implement secure cookies by ensuring all session cookies have the "Secure" flag.

References

[OWASP - Insufficient Transport Layer Protection](#)

H1: Lack of Web Application Firewall

Matrix Calculation		CVSS Score	Risk
Impact	High	N/A	High
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1037: Filter Network Traffic M1050: Exploit Protection	
Affected Scope			

Description

Web servers on APT's network lack any form of web application firewalls to protect websites from attacks. The absence of a web application firewall increases the chances that a vulnerable web application will be exploited by a threat actor using common website exploitation techniques.

Business Impact

The lack of website protection leaves APT open to attacks on the website, leading to a loss of sensitive customer data and potentially cause disrupting operations.

Steps to Reproduce

N/A

Remediations

Team-XX recommends the following:

1. Deploy Web Application Firewalls (WAFs) on all servers that currently host websites, prioritizing those that are publicly accessible.

References

[Palo Alto Networks: How to Deploy Web Application Firewalls](#)

Oracle - Web Application Firewall Policies

H1: Lack of Network Segmentation

Matrix Calculation		CVSS Score	Risk
Impact	High	N/A	High
Likelihood	High		
CVSSv4.0 Attack Vector		N/A	
MITRE ATT&CK	Techniques	T1210: Exploitation of Remote Services	
	Mitigations	M1030: Network Segmentation	
Affected Scope			

Description

Multiple hosts are reachable across a flat network without any zone-based controls separating them. A successful compromise of a single host grants attackers the ability to pivot into adjacent systems in APT's network.

Business Impact

If an attacker can pivot into a sensitive system, they will be able to extract critical data and cause a large-scale disruption, possibly causing damage to the ship and a mass loss of life.

Steps to Reproduce

N/A

Remediations

Team-XX recommends the following:

1. Implement Network Segmentation to isolate publicly accessible applications from critical systems that are needed for the cruise's operational functionality
2. Apply least privileged network access to only allow required communications between machines to take place

3. Regularly audit segmentation controls through network scans and firewall reviews.

References

[Nordlayer - Network Segmentation Best Practices](#)

[Splunk - Guide to Network Segmentation](#)

H1: Named Pipe Impersonation

Matrix Calculation		CVSS Score	Risk
Impact	High	8.5	High
Likelihood	Medium		
CVSSv4.0 Attack Vector		AV:L/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1608: Exploitation for Privilege Escalation T1134.001: Access Token Manipulation - Token Impersonation/Theft	
	Mitigations	M1026: Privileged Account Management M1022: Restrict File and Directory Permissions	
Affected Scope			

Description

The **machine** creates named pipes with weak security permissions, allowing low-privileged users to connect with and impersonate privileged processes. When the **machine service** runs with elevated privileges (SYSTEM or Administrator), attackers can abuse named pipe connections to escalate their privileges to that of the service account, gaining full control over the system.

Business Impact

If an attacker gains complete control of the **machine**, allowing them to shut down critical services running on the **machine**, see sensitive documents stored on it, and also use the **machine** to pivot and attack other **machines**.

Steps to Reproduce

- Step 1: Get a Meterpreter shell as a low-privilege user
- Step 2: Run `getuid` to see our session is running as regular account
- Step 3: Run `"use priv"` to load the priv extension in Meterpreter
- Step 4: Run `"getsystem"` to exploit the named pipe impersonation priv esc

Step 5: Run getuid to see our session is running as SYSTEM or Administrator

Remediations

Team-XX recommends the following:

1. Implement proper named pipe security descriptors to restrict access only to authorized users and prevent impersonation
2. Disable impersonation on named pipes unless absolutely required for business functionality
3. Run the application service with least privilege using a dedicated service account with minimal permissions rather than SYSTEM or Administrator accounts
4. Regularly audit service permissions and named pipe ACLs.

References

[Microsoft - Named Pipe Security and Access Rights](#)

H1: Password in User Description

Matrix Calculation		CVSS Score	Risk
Impact	High	8.6	High
Likelihood	High		
CVSSv4.0 Attack Vector		<u>AV:L/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:L/SI:L/SA:L</u>	
MITRE ATT&CK	Techniques	<u>T155: Credentials from Password Stores</u>	
	Mitigations	<u>M1027: Password Policies</u>	
Affected Scope			

Description

The password for USER was found publicly exposed within the user's account description on the APPLICATION.

Business Impact

Having access to the user's cleartext password allows the attacker to impersonate the user and potentially access their PII. Depending on the privileges of the compromised user, the attacker can potentially compromise other aspects of the application, laterally move across the system, and/or access the PII of other users.

Steps to Reproduce

Remediations

Team-XX recommends the following:

1. Require the use of multi-factor authentication (MFA) by all users in order to minimize the risks of users exposing their own credentials.
2. Implement and enforce a strong password policy for all accounts to ensure attackers are unable easily brute force passwords. As a baseline the following minimum password policy is recommended:
 - a. Minimum of 12 characters

- b. At least one uppercase character, one lowercase character, one digit character, and one special symbol.
- c. Unique passwords for each user and service to prevent password reuse

References

[DigiCert - Creating Password Policy Best Practices](#)

[Palo Alto Networks - What is Multifactor Authentication \(MFA\) Implementation?](#)

H1: Privileged Public API Key

Matrix Calculation		CVSS Score	Risk
Impact	High	8.3	High
Likelihood	High		
CVSSv4.0 Attack Vector		CVSS:4.0/AV:N/AC:L/AT:P/PR:N/UI:N/VC:H/VI:L/VA:N/SC:N/SI:N/SA:N	
MITRE ATT&CK	Techniques	T1190: Exploit Public-Facing Application	
	Mitigations	M1054: Software Configuration	
Affected Scope			

Description

An API key for the **APPLICATION** application is contained within the client-side source code and is not unprivileged, i.e., it allows an attacker to **READ DATABASE/EXECUTE SOME COMMAND**.

Business Impact

Having this privileged API key available to the client allows any user to read all information from the database and perform actions as an administrator, which can result in the leakage of PII or a compromise in the integrity of the system.

Steps to Reproduce

Depends on application

Remediations

Team-XX recommends the following:

1. Immediately reduce the permission level of the exposed API key, and
2. Regenerate the affected API key as a precaution

References